

CISM Exam Study Guide

Certified Information Security Manager — Final Review Notes

1. Exam Essentials

Item	Detail
Questions	150 multiple-choice questions
Time	4 hours (240 minutes) — about 1 min 36 sec per question
Scoring	Scaled 200–800; passing score = 450 (roughly 70–75% correct, not a fixed percentage)
Domain 1	Information Security Governance — 17%
Domain 2	Information Security Risk Management — 20%
Domain 3	Information Security Program — 33%
Domain 4	Incident Management — 30%
Certification	Passing the exam alone does not certify you: you must also apply with 5 years of infosec experience, incl. 3 years in security management (some waivers available)

2. The Terminology Ladder — Untangling Domains 1 & 3

These five terms form a strict top-down hierarchy. Each level directs the one below it and is constrained by the one above it. Memorize the ladder first; the definitions then fall into place.

THE LADDER: Enterprise Governance → Enterprise (Business) Strategy → Information Security Governance → Information Security Strategy → Information Security Program → Projects & Operations

One-line logic: Governance decides WHY and WHO decides. Strategy is the PLAN (what, by when). The Program is the ongoing EXECUTION (how, every day). A project is a temporary piece of the program.

Term	What it is	Key question it answers	Who owns it	Exam cue
Enterprise Governance	The system by which the WHOLE organization is directed and controlled. Sets corporate objectives, values, accountability, and risk appetite.	How is the entire organization directed and held accountable?	Board of Directors	Broadest scope. Security governance must fit INSIDE it.
Enterprise (Business) Strategy	The organization's long-term plan to achieve its mission and business goals (growth, markets, products).	Where is the business going?	Board + executive management	It is an INPUT to security. Security aligns TO it — never the reverse.

Term	What it is	Key question it answers	Who owns it	Exam cue
Information Security Governance	A SUBSET of enterprise governance: the system that directs and controls security activities so they support business objectives. Delivers oversight, accountability, policy, and resource decisions.	How do we direct, control, and oversee security?	Board + senior management (steering committee); CISO facilitates	Answers with "board," "oversight," "accountability," "alignment" = governance.
Information Security Strategy	The long-term PLAN / roadmap defining how security will support the enterprise strategy. Bridges the current state to the desired state (gap analysis → roadmap → business case).	What must security achieve, and by when?	CISO develops; senior management approves	Answers with "roadmap," "desired state," "alignment with business objectives" = strategy.
Information Security Program	The ongoing collection of activities, projects, resources, and controls that EXECUTES the strategy: policies in action, controls, awareness training, metrics, vendor management.	How do we carry out the strategy day-to-day?	CISO / information security manager	Answers with "implement," "resources," "controls," "training," "operate" = program.

Memory hooks

- **Governance = steering wheel and guardrails.** It does not drive; it decides direction and checks the driving (Evaluate – Direct – Monitor).
- **Strategy = the route on the map.** A documented plan from current state to desired state.
- **Program = the journey itself.** Continuous execution; never "finished." A project (e.g., deploy MFA) ends; the program does not.
- **Direction of alignment (tested constantly):** Security strategy aligns with business/enterprise strategy. The business never aligns to security.

2.1 Governance vs. Management

	Governance	Management
Core verbs	Evaluate, Direct, Monitor (EDM — COBIT)	Plan, Build, Run, Monitor
Answers	Are we doing the RIGHT things?	Are we doing things RIGHT?
Who	Board and senior management	CISO and managers
Output	Direction, priorities, accountability, risk appetite	Execution, day-to-day decisions, operations

2.2 Policy vs. Standard vs. Procedure vs. Guideline

Document	What it is	Mandatory?	Approved by	Example
Policy	High-level statement of management INTENT and direction; changes rarely	Yes	Senior management / board	"All sensitive data must be protected against unauthorized access."
Standard	Specific, measurable requirements that enforce the policy	Yes	Security management	"AES-256 encryption for data at rest."
Procedure	Step-by-step instructions to perform a task	Yes	Process owners	"How to provision a new user account."
Guideline	Recommended, flexible advice	No (optional)	Security team	"Suggested password-manager practices."

Hierarchy: Strategy → Policy → Standard → Procedure (each derives from the one before). Guidelines sit alongside as optional support. Policies must flow from the strategy — a policy that conflicts with strategy is the wrong answer.

2.3 Other frequently confused pairs

- **Strategy vs. Architecture:** strategy = the plan/direction; security architecture = the structural blueprint (technical and process design) used to implement it.
- **Program vs. Project:** program = permanent, ongoing, umbrella; project = temporary, defined start/end, delivers one outcome into the program.
- **Due diligence vs. Due care:** diligence = investigate/verify BEFORE acting (e.g., vendor assessment); care = ongoing reasonable actions to protect (e.g., patching, monitoring). Diligence = "do detect," care = "do correct."
- **Business case vs. Feasibility study:** feasibility asks "CAN we do it?"; the business case asks "SHOULD we do it — what is the value?" The business case justifies investment and comes before funding.
- **Gap analysis:** compares CURRENT state to DESIRED state; the gap defines the strategy/roadmap. It is the standard "first step" after objectives are known.
- **Charter:** formal document giving the security program its mandate and authority, endorsed by senior management.

3. Domain 1 — Information Security Governance (17%)

3A. Enterprise Governance

- **Organizational culture:** security governance must fit the culture; changing behavior needs senior-management tone-at-the-top plus awareness. Culture eats policy for breakfast — if they clash, address culture.
- **Legal, regulatory & contractual requirements:** identify obligations (GDPR, HIPAA, PCI DSS, contracts) as governance INPUTS. When laws conflict across jurisdictions, generally follow the most restrictive applicable requirement and consult legal counsel.
- **Structures, roles & responsibilities:**

- **Board of Directors:** ultimately accountable; sets risk appetite; provides governance oversight.
- **Senior management:** provides resources, approves policy and strategy, accepts risk.
- **Steering committee:** cross-functional body aligning security with business units; sets priorities; best vehicle for org-wide buy-in.
- **CISO / security manager:** develops strategy, runs the program, advises — does NOT accept risk for the business.
- **Data owner:** business role; classifies data and approves access. **Custodian:** (usually IT) implements protection per the owner's requirements. **User:** complies with policy.

3B. Information Security Strategy

- **Development sequence (classic exam sequence):** understand business objectives → assess current state (incl. risk) → define desired state → gap analysis → roadmap → business case → approval & resources.
- **First step is ALWAYS** understanding business objectives / obtaining senior management commitment — never buying tools or writing policy.
- **Frameworks & standards:** COBIT 2019 (governance of enterprise IT), ISO/IEC 27001 (ISMS requirements, certifiable), ISO/IEC 27002 (controls guidance), NIST CSF, ISO 27014 (security governance). Frameworks are adapted, not adopted blindly.
- **Strategic planning:** budgets, resources, business case, ROSI. The business case links security investment to business value and is the best tool to win management support.

Six expected outcomes of security governance (know these!)

- 1. Strategic alignment · 2. Risk management · 3. Value delivery · 4. Resource optimization · 5. Performance measurement · 6. Assurance process integration

Metrics for governance

Metric	Measures	Audience / use	Example
KGI (Key Goal Indicator)	Whether a GOAL was achieved (after the fact)	Board / executives — outcome view	“Zero regulatory findings this year”
KPI (Key Performance Indicator)	How well a PROCESS is performing (leading/ongoing)	Management — process view	“98% of critical patches within 14 days”
KRI (Key Risk Indicator)	Early-warning signal that RISK exposure is rising	Risk owners — predictive view	“Spike in phishing click-rate”

Metric rule: a good metric is relevant to its audience and supports a decision. Board metrics = business impact and trends, not technical counts.

4. Domain 2 — Information Security Risk Management (20%)

4A. Risk Assessment

- **Order of operations:** identify assets → identify threats & vulnerabilities → analyze likelihood & impact → evaluate against risk appetite → treat. Risk assessment always precedes control selection.
- **Risk components:** Risk = likelihood that a THREAT exploits a VULNERABILITY causing IMPACT to an asset. No vulnerability or no threat ⇒ no risk.
- **Analysis types:** Quantitative (monetary: SLE, ALE), Qualitative (high/medium/low, scenarios, workshops), Semi-quantitative (scored scales). Qualitative is faster and used when data is scarce.
- **Formulas:** $SLE = \text{Asset Value} \times \text{Exposure Factor}$. $ALE = SLE \times ARO$ (annualized rate of occurrence). A control is justified when its cost is less than the ALE reduction it delivers.

Appetite vs. Tolerance vs. Capacity

Term	Meaning	Set by	Hook
Risk appetite	Broad AMOUNT/type of risk the organization is WILLING to accept in pursuit of its goals	Board	“Willing” — a choice
Risk tolerance	Acceptable DEVIATION from appetite for a specific objective	Senior management	“Wiggle room” per objective
Risk capacity	MAXIMUM risk the organization can ABSORB and survive	Objective fact (financial reality)	“Able” — a hard limit. Capacity ≥ appetite

4B. Risk Response

- **Four treatment options:** **Mitigate** (apply controls), **Accept** (informed decision by risk owner — within appetite), **Avoid** (stop the activity), **Transfer/Share** (insurance, outsourcing — note: legal accountability can NEVER be transferred).
- **Inherent risk** = before controls. **Residual risk** = after controls; must be reduced to within appetite, then formally accepted by the risk owner / senior management — never by the CISO alone.
- **Risk & control ownership:** every risk needs a named business owner who makes treatment decisions; control owners operate controls. The security manager facilitates and advises.
- **Risk register:** the living inventory of risks, owners, treatments, and status — the primary tool for monitoring and reporting.
- **Monitoring & reporting:** KRIs give early warning; report risk in business terms; reassess when the environment changes (new tech, M&A, new law, major incident).
- **Third-party risk:** assess before contracting (due diligence), embed requirements + right-to-audit + SLAs in the contract, monitor continuously.

Control categories & types

Dimension	Types	Examples
By nature	Administrative / Technical / Physical	Policy & training / firewall, encryption / locks, guards
By function	Preventive · Detective · Corrective · Deterrent · Compensating	MFA · IDS, logs · backups, patching · warning banner · extra monitoring when primary control is infeasible

5. Domain 3 — Information Security Program (33% — biggest domain!)

Anchor concept: the program EXECUTES the strategy. Every program decision traces back to strategy, which traces to business objectives. If a question asks what the program must align with → the information security strategy (and through it, business objectives).

5A. Program Development

- **First step in building a program:** define objectives derived from the strategy (not hiring, not tools). A program charter endorsed by senior management gives it authority.
- **Program resources:** people, budget, tools, skills. Resource requests are justified through the business case / risk reduction, not fear.
- **Asset identification & classification:** inventory first; the DATA OWNER classifies based on business value, sensitivity, and impact of loss; classification drives the level of protection (cost-effective — don't over-protect low-value assets).
- **Industry standards & frameworks:** ISO 27001/27002, NIST SP 800-53, NIST CSF, COBIT. Choose/adapt a framework to structure the program and enable benchmarking.
- **Policies, procedures, guidelines:** the program turns policy into operational reality (see table 2.2).
- **Program metrics:** measure progress toward strategy objectives; tailor to audience; trends matter more than snapshots. A metric nobody acts on is noise.

5B. Program Management

- **Control design & selection:** driven by risk assessment and control objectives; balance cost vs. risk reduction; prefer the control that best reduces risk at acceptable cost.
- **Control implementation & integration:** embed security into existing business processes — HR (onboarding/offboarding), procurement, change management, SDLC/DevOps (security earliest in the lifecycle = cheapest). Security should be an enabler, not a roadblock.
- **Control testing & evaluation:** test controls for design AND operating effectiveness (audits, vulnerability assessments, pen tests); feed results back into the program.
- **Awareness & training:** the most effective lever for changing security culture and reducing human-factor risk; role-based; measure effectiveness (e.g., phishing simulations); repeat regularly.
- **Management of external services (outsourcing/cloud):** security requirements and SLAs go INTO THE CONTRACT before signing; right-to-audit clause; monitor performance against SLAs. You can outsource the function, never the accountability.

- **Program communications & reporting:** regular reporting to steering committee/senior management in business terms; demonstrates value and keeps commitment.

6. Domain 4 — Incident Management (30%)

6A. Incident Management Readiness

- **Event vs. Incident vs. Disaster:** event = any observable occurrence; incident = an event that harms (or threatens) confidentiality, integrity, or availability; disaster = an incident causing major, prolonged disruption that triggers BCP/DRP.
- **Incident response plan (IRP):** defines roles, severity classification, escalation, and communication BEFORE incidents happen; requires senior-management approval; who may declare an incident/disaster must be defined in advance.
- **BIA (Business Impact Analysis):** identifies critical processes and the impact of downtime over time; it is the BASIS for recovery priorities, RTO/RPO, and BCP/DRP strategy. BIA comes first — before choosing recovery strategies.
- **BCP vs. DRP:** BCP keeps the BUSINESS running (people, processes, workarounds); DRP restores IT/technology. DRP is a subset supporting the BCP.

Recovery metrics (memorize cold)

Metric	Meaning	Hook
RTO — Recovery Time Objective	Target time to restore a system/process after disruption	“How long can it be DOWN?”
RPO — Recovery Point Objective	Maximum tolerable DATA loss, measured backward in time	“How much data can we lose?” — drives backup frequency
AIW — Acceptable Interruption Window	Maximum total downtime before severe/unrecoverable business damage (≈ MTD)	RTO must fit inside AIW
SDO — Service Delivery Objective	Minimum service level to maintain WHILE operating in alternate/recovery mode	“How much service during recovery?”
MTO — Maximum Tolerable Outage	Maximum time the organization can operate in ALTERNATE mode	Limits how long you can stay at the backup site

Testing types (least → most disruptive)

- 1. **Checklist review** (read the plan) → 2. **Structured walkthrough / tabletop** (talk through scenarios) → 3. **Simulation** (act out, no real systems) → 4. **Parallel test** (recovery site runs alongside production) → 5. **Full interruption** (production actually switched over — most realistic, most risky, needs management approval).

Recovery site options

Site	Readiness	Cost	Recovery speed
Hot site	Fully equipped, near-real-time data	Highest	Hours

Site	Readiness	Cost	Recovery speed
Warm site	Equipped, data restored from backups	Medium	Hours–days
Cold site	Empty facility (power/space only)	Lowest	Days–weeks
Reciprocal agreement	Mutual aid with another organization	Low	Unreliable — rarely the right answer

6B. Incident Management Operations

- **Lifecycle:** Preparation → Detection & analysis (identify, triage, classify severity) → Containment → Eradication → Recovery → Post-incident review / lessons learned.
- **Containment first:** once an incident is confirmed, the priority is limiting damage (contain) — before eradication and before detailed investigation. But never destroy evidence needlessly.
- **Communications:** follow the predefined plan — who informs management, regulators (breach-notification deadlines!), customers, law enforcement, media. One authorized spokesperson.
- **Forensics basics:** preserve evidence integrity; document chain of custody; collect in order of volatility (RAM/network state first, disk later); use forensic copies, work on images not originals.
- **Post-incident review:** blameless lessons-learned; root cause; update the IRP, controls, and training — this closing of the loop is the most valuable, most-tested step.

7. Exam Mindset — “Think Like a Manager”

- Business alignment beats technical perfection. If one option mentions business objectives/strategy alignment, it is very often correct.
- FIRST-question logic: understand business objectives → assess risk → then act. “Perform a risk assessment” is the classic correct FIRST step before selecting controls.
- The CISO advises and facilitates; SENIOR MANAGEMENT decides, approves, and accepts risk.
- Governance/management-process answers usually beat pure technology answers. People and process > products.
- Everything is risk-based and cost-justified: never spend more on a control than the risk is worth.
- Sequences to recognize: Strategy → Policy → Standard → Procedure. Risk assessment → Control selection. BIA → RTO/RPO → Recovery strategy. Contain → Eradicate → Recover.
- Watch for BEST / MOST / FIRST / PRIMARY: several answers are “true” — pick the most strategic, most business-aligned, or earliest-in-sequence one.
- Time management: ~1.5 min per question; answer everything (no penalty for guessing); flag and return.

8. Rapid Drill — “If the question says... think...”

If the question says...	...the answer concept is
“Ultimately accountable for information security”	Board of Directors
“Best way to get organization-wide buy-in / alignment across departments”	Security steering committee
“First step in developing a security strategy”	Understand business objectives
“Best justification for security investment”	Business case (value / risk reduction in business terms)
“Difference between current and desired security state”	Gap analysis
“Who classifies data / approves access”	Data owner (business), not IT
“Who implements the protection”	Data custodian (IT)
“Who accepts residual risk”	Risk owner / senior management — never the CISO alone
“Amount of risk the board is willing to take”	Risk appetite
“Most effective way to change security behavior/culture”	Security awareness & training (with tone from the top)
“Security requirements for an outsourced service — when?”	In the contract/SLA, BEFORE signing
“What drives recovery priorities, RTO and RPO”	Business Impact Analysis (BIA)
“Incident confirmed — what first?”	Contain the damage (per the IR plan)
“Most important activity after an incident is closed”	Post-incident review / lessons learned
“The program must align with...”	The information security strategy (→ business objectives)
“Cheapest point to add security to a system”	Earliest phase of the SDLC (design/requirements)

9. Formula & Acronym Sheet

Item	Formula / expansion
SLE	Single Loss Expectancy = Asset Value × Exposure Factor
ALE	Annualized Loss Expectancy = SLE × ARO (Annualized Rate of Occurrence)
ROSI	Return on Security Investment = (ALE reduction – control cost) ÷ control cost
Control justification	Control cost < risk reduction (ALE before – ALE after)
EDM	Evaluate, Direct, Monitor — COBIT governance
CIA	Confidentiality, Integrity, Availability

Item	Formula / expansion
KGI / KPI / KRI	Goal (outcome) / Performance (process) / Risk (early warning) indicators
RTO / RPO / AIW / SDO / MTO	Downtime target / data-loss limit / max interruption window / service level in alternate mode / max time in alternate mode
ISMS	Information Security Management System (ISO/IEC 27001)
BIA / BCP / DRP / IRP	Impact analysis / business continuity / disaster recovery / incident response plans

10. Sources & Final-Week Checklist

- Official: ISACA CISM Exam Content Outline (isaca.org/credentialing/cism/cism-exam-content-outline); ISACA CISM Review Manual 16th Ed.; ISACA QAE database (official practice questions — the closest to real exam style).
- Days 1–4: one domain per day using these notes; drill the Section 8 table until instant.
- Days 5–6: full timed 150-question practice test; review EVERY wrong answer and map it to a section here.
- Day 7: light review of Sections 2, 7 and 8 only. Sleep well — the exam rewards calm, manager-level judgment.